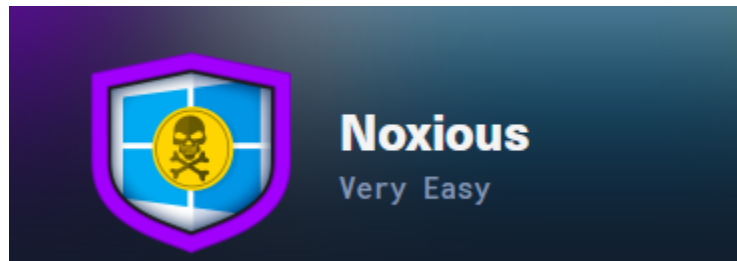


Hack The Box Noxious



The IDS device alerted us to a possible rogue device in the internal Active Directory network. The Intrusion Detection System also indicated signs of LLMNR traffic, which is unusual. It is suspected that an LLMNR poisoning attack occurred. The LLMNR traffic was directed towards Forela-WKstn002, which has the IP address 172.17.79.136. A limited packet capture from the surrounding time is provided to you, our Network Forensics expert. Since this occurred in the Active Directory VLAN, it is suggested that we perform network threat hunting with the Active Directory attack vector in mind, specifically focusing on LLMNR poisoning.

Task 1

It is suspected by the security team that there was a rogue device in Forela's internal network running responder tool to perform an LLMNR Poisoning attack. Please find the malicious IP Address of the machine.

```
ip.addr == 172.17.79.136 && llmnr
```

Why did i filter this is because it said LLMNR attack which is a Link-Local Multicast Name Resolution, Windows uses it as a fallback when DNS cannot resolve a hostname. The victim machine Forela-WKstn002 ip address is 172.17.79.136.

Address A	Address B
172.17.79.135	172.17.79.136
172.17.79.136	224.0.0.252

Seeing the conversation only this ip interact with the Forela-WKstn002 so the malicious ip is:

172.17.79.135

Task 2

What is the hostname of the rogue machine?

```
172.17.79.135 172.17.79.254 DHCP 324 DHCP Request - Transaction ID 0x481fed6  
Maximum DHCP Message Size: 655  
Option: (12) Host Name  
Length: 4  
Host Name kali  
Option: (255) End
```

Task 3

Now we need to confirm whether the attacker captured the user's hash and it is crackable!! What is the username whose hash was captured?

Found this rdp packet, the packet detail show name john.deacon

```
Remote Desktop Protocol  
Routing Token/Cookie: Cookie: msthash:john.deacon  
Type: RDP Negotiation Request (0x01)
```

Task 4

In NTLM traffic we can see that the victim credentials were relayed multiple times to the attacker's machine. When were the hashes captured the First time?

Filter : ntlmssp.message.type == 3

```
9292 2024-06-24 11:18:30.922052 f
```

2024-06-24 11:18:30

Task 5

What was the typo made by the victim when navigating to the file share that caused his credentials to be leaked?

```
▼ Link-local Multicast Name Resolution (response)
  Transaction ID: 0x2c01
  ▶ Flags: 0x8000 Standard query response, No error
  Questions: 1
  Answer RRs: 1
  Authority RRs: 0
  Additional RRs: 0
  ▼ Queries
    ▼ DCC01: type AAAA, class IN
      Name: DCC01
      [Name Length: 5]
      [Label Count: 1]
      Type: AAAA (28) (IP6 Address)
      Class: IN (0x0001)
  ▼ Answers
    ▼ DCC01: type AAAA, class IN, addr fe80::2068:fe84:5fc8:efb7
      Name: DCC01
      Type: AAAA (28) (IP6 Address)
      Class: IN (0x0001)
      Time to live: 30 (30 seconds)
      Data length: 16
      AAAA Address: fe80::2068:fe84:5fc8:efb7
      [Unsolicited: True]
```

the victim tried to resolve that hostname through LLMNR.

Task 6

To get the actual credentials of the victim user we need to stitch together multiple values from the ntlm negotiation packets. What is the NTLM server challenge value?

Filter : ntlmssp.messageType == 2

```
▶ Negotiate Flags: 0xe2898715 Negotiate 5b, Negotiate 5c, Negotiate 5d, Negotiate 5e, Negotiate 5f, Negotiate 60, Negotiate 61, Negotiate 62, Negotiate 63, Negotiate 64, Negotiate 65, Negotiate 66, Negotiate 67, Negotiate 68, Negotiate 69, Negotiate 6a, Negotiate 6b, Negotiate 6c, Negotiate 6d, Negotiate 6e, Negotiate 6f, Negotiate 70, Negotiate 71, Negotiate 72, Negotiate 73, Negotiate 74, Negotiate 75, Negotiate 76, Negotiate 77, Negotiate 78, Negotiate 79, Negotiate 7a, Negotiate 7b, Negotiate 7c, Negotiate 7d, Negotiate 7e, Negotiate 7f, Negotiate 80, Negotiate 81, Negotiate 82, Negotiate 83, Negotiate 84, Negotiate 85, Negotiate 86, Negotiate 87, Negotiate 88, Negotiate 89, Negotiate 8a, Negotiate 8b, Negotiate 8c, Negotiate 8d, Negotiate 8e, Negotiate 8f, Negotiate 90, Negotiate 91, Negotiate 92, Negotiate 93, Negotiate 94, Negotiate 95, Negotiate 96, Negotiate 97, Negotiate 98, Negotiate 99, Negotiate 9a, Negotiate 9b, Negotiate 9c, Negotiate 9d, Negotiate 9e, Negotiate 9f, Negotiate a0, Negotiate a1, Negotiate a2, Negotiate a3, Negotiate a4, Negotiate a5, Negotiate a6, Negotiate a7, Negotiate a8, Negotiate a9, Negotiate aa, Negotiate ab, Negotiate ac, Negotiate ad, Negotiate ae, Negotiate af, Negotiate b0, Negotiate b1, Negotiate b2, Negotiate b3, Negotiate b4, Negotiate b5, Negotiate b6, Negotiate b7, Negotiate b8, Negotiate b9, Negotiate ba, Negotiate bb, Negotiate bc, Negotiate bd, Negotiate be, Negotiate bf, Negotiate c0, Negotiate c1, Negotiate c2, Negotiate c3, Negotiate c4, Negotiate c5, Negotiate c6, Negotiate c7, Negotiate c8, Negotiate c9, Negotiate ca, Negotiate cb, Negotiate cc, Negotiate cd, Negotiate ce, Negotiate cf, Negotiate d0, Negotiate d1, Negotiate d2, Negotiate d3, Negotiate d4, Negotiate d5, Negotiate d6, Negotiate d7, Negotiate d8, Negotiate d9, Negotiate da, Negotiate db, Negotiate dc, Negotiate dd, Negotiate de, Negotiate df, Negotiate e0, Negotiate e1, Negotiate e2, Negotiate e3, Negotiate e4, Negotiate e5, Negotiate e6, Negotiate e7, Negotiate e8, Negotiate e9, Negotiate ea, Negotiate eb, Negotiate ec, Negotiate ed, Negotiate ee, Negotiate ef, Negotiate f0, Negotiate f1, Negotiate f2, Negotiate f3, Negotiate f4, Negotiate f5, Negotiate f6, Negotiate f7, Negotiate f8, Negotiate f9, Negotiate fa, Negotiate fb, Negotiate fc, Negotiate fd, Negotiate fe, Negotiate ff
  NTLM Server Challenge: 601019d191f054f1
  Reserved: 0000000000000000
```

Task 7

Now doing something similar, find the NTProofStr value.

Filter : ntlmssp.messageType == 3

```
NTLMv2 Response [...]: c0cc803a6d9fb5a9082253a04dbd4cd4  
NTProofStr: c0cc803a6d9fb5a9082253a04dbd4cd4  
response version: 1
```

Task 8

To test the password complexity, try recovering the password from the information found from packet capture. This is a crucial step as this way we can find whether the attacker was able to crack this and how quickly.

```
Offset: 176  
NTLMv2 Response [...]: c0cc803a6d9fb5a9082253a04dbd4cd4  
NTProofStr: c0cc803a6d9fb5a9082253a04dbd4cd4  
john.deacon::FORELA:601019d191f054f1:c0cc803a6d9fb5a9082253a04dbd4cd4
```

We take the whole response and combine it with NTLM server challenge value, username and domain.

```
JOHN.DEACON::FORELA:601019d191f054f1:c0cc803a6d9fb5a9082253a04dbd4cd4  
5700540004003400570049004e002d00360036004100530035004c00310047005200  
004c000700080080e4d59406c6da01060004000200000000000000000000000000  
73002f00440043004300300031000000000000000000000000000000000000000000):NotMyPassword0k?
```

Hashcat with rockyou.txt wordlist and we get the password

Task 9

Just to get more context surrounding the incident, what is the actual file share that the victim was trying to navigate to?

```
174 Tree Connect Request Tree: \\DC01\DC-Confidential
```

The name of the path is already attractive to the attacker.